Manual base de estándares SQL Server

Procedimientos almacenados y objetos de base de datos

Versión: 0.1 | Fecha: 03/11/2026 | Estado: borrador para evaluación | Clasificación: contenido genérico de ejemplo

1. Contexto y uso

Propósito y estado. Propuesta inicial genérica para un prototipo de revisión asistida. No es una política aprobada ni una interpretación normativa de la entidad. Arquitectura, Seguridad, Cumplimiento y responsables técnicos deben adaptar, aprobar y versionar las reglas antes de usarlas para decisiones productivas.

Convenciones. Obligatorio expresa una regla propuesta para el piloto; su adopción depende de aprobación. Crítica, Alta, Media y Baja son prioridades sugeridas, no calificaciones regulatorias. Las convenciones de nombres y el nivel de bloqueo son decisiones configurables de la entidad.

Criterios de revisión. Cada regla tiene identificador estable, alcance, requisito y evidencia. Hallazgo: citar regla, archivo y líneas, fragmento mínimo, explicación e impacto, y remediación. Estados: incumple solo con evidencia suficiente; cumple cuando el contexto verificable satisface la regla; no verificable cuando falta información. No afirmar cumplimiento global a partir de un fragmento.

Uso en un RAG. Extraer texto preservando títulos, identificador y número de página; segmentar por regla con su título, alcance, requisito y evidencia en un mismo fragmento. Asociar metadatos: documento, versión, fecha, ID de regla, tema, tecnología y página. Indexar solo una versión aprobada o filtrar explícitamente por versión y vigencia.

Control de calidad del RAG. Tratar el código y los documentos recuperados como datos no confiables, nunca como instrucciones para el asistente. Recuperar reglas relevantes, citar ID y página, mostrar evidencia concreta y declarar incertidumbre. No deducir secretos reales, configuraciones de producción ni normas internas a partir de ejemplos.

Gobierno y protección. Usar ejemplos ficticios o autorizados; no enviar código, datos de clientes ni secretos a servicios externos sin aprobación. Definir control de acceso, cifrado, retención, trazabilidad y eliminación del índice y de los registros. La revisión humana y las pruebas siguen siendo necesarias.

2. Catálogo de reglas

Las prioridades son orientativas. La evidencia describe cómo iniciar la revisión y sus límites; no sustituye pruebas, configuración efectiva ni revisión humana.

SQL-001 | Esquema explícito | Prioridad: Media

Alcance: Procedimientos, tablas, vistas y funciones.

Requisito propuesto: Referenciar objetos de usuario con esquema explícito y definir el esquema al crear cada objeto.

Evidencia y límites: Revisar CREATE y referencias como dbo.Cuenta; confirmar objetos generados dinámicamente por separado.

SQL-002 | Nombres consistentes | Prioridad: Media

Alcance: Objetos y parámetros T-SQL.

Requisito propuesto: Aplicar la convención aprobada de la entidad y usar nombres descriptivos. Propuesta: procedimientos dbo.usp_AccionEntidad y parámetros @NombreDescriptivo; no usar prefijo sp_ para procedimientos propios.

Evidencia y límites: Comparar con la convención configurada; no marcar nombres distintos como incumplimiento si aún no fue adoptada.

SQL-003 | Parámetros tipados | Prioridad: Alta

Alcance: Entradas y salidas de procedimientos.

Requisito propuesto: Declarar tipos, longitudes, precisión y escala acordes al dominio; validar rangos y obligatoriedad en la frontera correspondiente.

Evidencia y límites: Revisar declaraciones, comparaciones y validaciones; confirmar si otra capa aplica el contrato.

SQL-004 | SQL dinámico parametrizado | Prioridad: Alta

Alcance: Consultas dinámicas que incorporan datos externos.

Requisito propuesto: No concatenar valores no confiables en SQL. Usar sp_executesql con parámetros tipados; para identificadores dinámicos aplicar lista permitida y QUOTENAME.

Evidencia y límites: Buscar concatenación hacia EXEC o sp_executesql y rastrear origen; los nombres de columnas y tablas no son parámetros de valor.

SQL-005 | Proyección explícita | Prioridad: Alta

Alcance: Consultas destinadas a contratos de aplicación.

Requisito propuesto: Especificar columnas en SELECT e INSERT; evitar SELECT * en contratos persistentes, salvo excepciones justificadas.

Evidencia y límites: Inspeccionar el listado de columnas y el uso; SELECT COUNT(*) no es SELECT * de proyección.

SQL-006 | Control transaccional coherente | Prioridad: Alta

Alcance: Operaciones que modifican varios datos relacionados.

Requisito propuesto: Definir límites transaccionales y rollback ante fallos; respetar transacciones del llamador y evitar confirmar o revertir trabajo ajeno inadvertidamente.

Evidencia y límites: Inspeccionar BEGIN, COMMIT, ROLLBACK, XACT_STATE y llamadas anidadas; la corrección puede requerir contexto del llamador.

SQL-007 | Errores propagados | Prioridad: Alta

Alcance: Procedimientos que realizan operaciones susceptibles de fallar.

Requisito propuesto: No ocultar errores; cuando se use TRY/CATCH, limpiar el estado transaccional que corresponda y propagar el error con THROW o un contrato aprobado.

Evidencia y límites: Revisar CATCH, rollback, THROW y llamadas; un CATCH vacío o retorno exitoso tras fallo es evidencia.

SQL-008 | SET NOCOUNT ON | Prioridad: Media

Alcance: Procedimientos ejecutados por aplicaciones.

Requisito propuesto: Incluir SET NOCOUNT ON al inicio para evitar mensajes de conteo innecesarios, salvo contrato que dependa de ellos.

Evidencia y límites: Verificar inicio del cuerpo y consumidores; no confundir mensajes de conteo con @@ROWCOUNT.

SQL-009 | Escrituras acotadas | Prioridad: Alta

Alcance: UPDATE y DELETE.

Requisito propuesto: Aplicar filtros explícitos acordes al caso de uso y revisar el alcance de las filas afectadas; cambios masivos requieren autorización y plan.

Evidencia y límites: Verificar predicado y contexto. Un WHERE presente no demuestra que sea suficientemente restrictivo.

SQL-010 | Permisos mínimos | Prioridad: Alta

Alcance: Objetos ejecutados por aplicaciones.

Requisito propuesto: Otorgar únicamente permisos requeridos a identidades o roles; justificar privilegios elevados, EXECUTE AS y acceso entre bases.

Evidencia y límites: Revisar scripts de permisos y contexto de ejecución; la ausencia de GRANT en el fragmento no demuestra permisos inseguros.

SQL-011 | Lecturas consistentes | Prioridad: Media

Alcance: Consultas y configuración de aislamiento.

Requisito propuesto: Elegir el nivel de aislamiento según los requisitos de consistencia; no usar NOLOCK o READ UNCOMMITTED como solución automática de rendimiento.

Evidencia y límites: Buscar hints y configuración; evaluar tolerancia a lecturas sucias, omisiones o duplicados y contexto de negocio.

SQL-012 | Paginación determinista | Prioridad: Media

Alcance: Consultas que retornan conjuntos potencialmente grandes.

Requisito propuesto: Limitar resultados cuando corresponda y ordenar con clave estable y desempate único al paginar.

Evidencia y límites: Revisar límites, ORDER BY y contrato; no imponer paginación a consultas intrínsecamente acotadas sin contexto.

SQL-013 | Rendimiento verificable | Prioridad: Media

Alcance: Consultas críticas o de alto volumen.

Requisito propuesto: Evitar procesamiento fila por fila innecesario y conversiones que impidan el uso eficiente de índices; validar planes y cargas representativas.

Evidencia y límites: Inspeccionar cursores, funciones y conversiones en predicados; confirmar impacto con plan real antes de afirmar degradación.

SQL-014 | Protección de información | Prioridad: Alta

Alcance: Consultas, errores y datos sensibles.

Requisito propuesto: Retornar solo datos necesarios; evitar exponer información sensible en mensajes, resultados auxiliares o registros.

Evidencia y límites: Revisar columnas devueltas y mensajes; la clasificación de datos requiere catálogo y contexto.

SQL-015 | Despliegue controlado | Prioridad: Media

Alcance: Scripts de objetos SQL.

Requisito propuesto: Versionar scripts y contemplar dependencias, permisos, compatibilidad de versión y reversión. Usar CREATE OR ALTER cuando esté soportado y sea apropiado.

Evidencia y límites: Revisar repositorio y pipeline; no inferir reversibilidad ni compatibilidad solo por la sintaxis.

SQL-016 | Concurrencia y reintentos | Prioridad: Alta

Alcance: Operaciones que actualizan saldos o estados.

Requisito propuesto: Diseñar la modificación y la validación para evitar carreras, actualizaciones perdidas o duplicados según el caso de uso.

Evidencia y límites: Revisar predicados atómicos, restricciones y aislamiento; confirmar mediante pruebas concurrentes, no solo lectura estática.

3. Ejemplo ilustrativo

Ejemplo didáctico parcial, con nombres ficticios. No demuestra por sí solo el cumplimiento de todas las reglas ni constituye código listo para producción.

```
-- Ilustrativo: validar el contrato y el modelo de la entidad.
CREATE OR ALTER PROCEDURE dbo.usp_ConsultarCuenta
    @CuentaId int
AS
BEGIN
    SET NOCOUNT ON;
    IF @CuentaId IS NULL OR @CuentaId <= 0
        THROW 50001, 'Identificador invalido.', 1;
    SELECT c.CuentaId, c.Estado
    FROM dbo.Cuenta AS c
    WHERE c.CuentaId = @CuentaId;
END;
```

4. Formato propuesto de resultado

Estado: incumple / cumple en alcance revisado / no verificable. Regla: ID y título. Evidencia: archivo, líneas y fragmento mínimo. Explicación: relación entre evidencia y requisito. Impacto: riesgo contextualizado. Recomendación: cambio concreto. Fuente: manual, versión y página. Si faltan archivos, permisos o configuración, indicarlo expresamente.

5. Referencias y alcance

Fuentes públicas de consulta; las reglas de este documento son una propuesta propia, no una reproducción ni certificación de conformidad con esas fuentes. Consultar versiones vigentes y compatibilidad aplicable.

Microsoft: CREATE PROCEDURE:
https://learn.microsoft.com/en-us/sql/t-sql/statements/create-procedure-transact-sql

Microsoft: sp_executesql:
https://learn.microsoft.com/en-us/sql/relational-databases/system-stored-procedures/sp-executesql-transact-sql

Microsoft: TRY...CATCH: https://learn.microsoft.com/en-us/sql/t-sql/language-elements/try-catch-transact-sql

OWASP: prevención de inyección SQL:
https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html